

Exchange Permission Audit Evidence Checklist

A repeatable field checklist for collection, normalization, review, remediation, and evidence retention

Use this checklist to make the audit reproducible.

Capture scope, collector health, raw evidence, identity resolution, configured versus effective access, review decisions, and post-change proof. Preserve raw source records even when expected entries are filtered from operational views.

1. Pre-collection controls

Audit / project name

Evidence date

Tenant / environment

Review period

Audit owner

Control / security owner

- ☐ Tenant and scope are approved before collection.
- ☐ Collector identity and least-privilege role are documented.
- ☐ Module, API, script, and collector versions are recorded.
- ☐ UTC start/end and EvidenceDate convention are defined.
- ☐ Evidence location is approved and access-controlled; sensitive data and secrets are minimized.

Pre-collection notes

Collection coverage

Confirm that every relevant permission control plane has an evidence path.

2. Required permission domains

- ☐ Full Access / mailbox permissions collected, including inheritance and Deny where exposed.
- ☐ Send As collected independently from Full Access.
- ☐ Send on Behalf collected independently from Full Access.
- ☐ Mailbox-folder and calendar permissions sampled or enumerated as required.
- ☐ Public-folder permissions collected with Default / Anonymous entries retained.
- ☐ Distribution-group ownership collected and inactive owners assessed.
- ☐ Role-group membership and effective RBAC assignments reviewed.
- ☐ Application registrations, service principals, consent, and Exchange mailbox scoping reviewed.
- ☐ Identity state enriched for disabled, guest, hidden, inactive, or unresolved trustees.
- ☐ Purview audit or other usage/change evidence correlated where required.

3. Collector run health

- ☐ No known errors
- ☐ Errors captured
- ☐ Throttling observed
- ☐ Partial run
- ☐ Coverage reconciled
- ☐ Requires rerun

Collection run ID

Collector version

Start / end UTC

Evidence hash / manifest

Expected target count

Collected target count

Coverage reconciliation / collector exceptions

Normalization and identity resolution

Turn source records into atomic, traceable entitlement rows without losing source semantics.

4. Evidence quality gates

- ☐ Raw output is retained and hashed.
- ☐ Critical fields required for analysis are present; incomplete records are quarantined.
- ☐ Stable target and trustee identifiers are retained.
- ☐ Inherited and Deny values are preserved.
- ☐ Original group grants remain distinguishable from derived effective members.
- ☐ Source and collection context are retained for every normalized row.
- ☐ ReviewStatus is populated only after the record passes quality gates.

5. Canonical record check

Target | TargetType | PermissionType | Trustee | TrusteeType | Inherited | Deny | Source | Scope | ReviewStatus | EvidenceDate

Normalization sample / source-to-row mapping

6. Identity resolution

- ☐ Object ID / GUID used where available.
- ☐ SID used when appropriate.
- ☐ External directory object ID used where available.
- ☐ Distinguished Name used when stable IDs are unavailable.
- ☐ Primary SMTP / proxy address used as a display or fallback attribute, not a durable key.
- ☐ UPN / alias used only as fallback identifiers.

- ☐ Display name is last-resort resolution and is explicitly marked when used.
- ☐ Unresolved or ambiguous identities are quarantined and not auto-removed.

Effective access analysis

Evaluate how direct, inherited, group-mediated, denied, and application access combine.

7. Configured versus effective access

- ☐ Configured entitlement is reported separately from derived effective access.
- ☐ Groups are expanded for effective-access analysis while the original group grant remains authoritative.
- ☐ Inheritance is preserved and interpreted according to the source control plane.
- ☐ Deny semantics are retained; no simplistic allow-minus-deny model is assumed across all sources.
- ☐ Application/service-principal scope is explicitly documented and tested.
- ☐ Disabled / hidden / guest / inactive states are assessed without equating one state with deletion.
- ☐ Privileged targets and trustees are classified for priority review.

8. High-risk review triggers

- ☐ Privileged mailbox or high-sensitivity target
- ☐ Broad group grant or unexpected group-mediated access
- ☐ Unresolved or ambiguous trustee
- ☐ Disabled account retaining direct access
- ☐ Public-folder Default / Anonymous access outside policy
- ☐ Send As on executive / finance / other privileged mailbox
- ☐ Application access with tenant-wide or unknown scope
- ☐ Service principal or group owner without accountable ownership
- ☐ Missing, stale, or expired review evidence

9. Usage evidence correlation

- ☐ Entitlement inventory supports a conclusion about what a trustee can access.
- ☐ Purview audit / telemetry is used where required to assess observed use.
- ☐ Inventory, change, and usage evidence are retained as separate evidence classes.

Effective-access findings / exceptions

Review and decision controls

Make ownership, decisions, exceptions, and remediation traceable.

10. Review lifecycle

- ☐ Unreviewed
- ☐ Pending security
- ☐ Approved exception
- ☐ Remediation in progress
- ☐ Rejected
- ☐ Expired
- ☐ Pending owner
- ☐ Approved
- ☐ Remediate
- ☐ Removed
- ☐ Unresolved

- ☐ Review owner is authenticated and accountable for the decision.
- ☐ Decision and rationale are retained.
- ☐ Time-bounded exception expiry is recorded where applicable.
- ☐ Remediation is authorized and ticketed before change.

Finding / decision reference	Decision date

Decision notes / rationale

Decision follow-up notes

Remediation and post-change validation

Authorize the change, capture the before-state, then re-collect and validate the outcome.

11. Remediation authorization

- ☐ Change is approved by the appropriate owner / control function.
- ☐ Before-state evidence is retained.
- ☐ Rollback values or commands are available where feasible.
- ☐ The evidence package remains access-controlled and discoverable.
- ☐ Sensitive data is minimized and handled under approved governance.

Change / remediation reference

Change owner

Remediation notes

12. Post-change checklist

- ☐ Post-change collection confirms the intended outcome.
- ☐ Before/after exports or normalized diffs are saved.
- ☐ Effective-access analysis is repeated where group, inheritance, or application scope changed.
- ☐ Independent service-level validation succeeds where the permission change affects a service workflow.
- ☐ Security and compliance controls remain effective.
- ☐ Rollback was either unnecessary and retained as an option, or executed and validated.
- ☐ Exceptions are still valid and monitored to expiry.
- ☐ Relevant audit/change events are retained where required.

Post-change validation and evidence package

Capture the durable evidence package that supports the final audit conclusion.

13. Evidence package inventory

Artifact	Location / owner	Retention / sensitivity
Case timeline		
Command / API transcript		
Before / after exports		
Raw evidence + hash / manifest		
Identity-resolution evidence		
Effective-access analysis		
Review decisions / tickets		
Validation proof		
Rollback evidence		
Redaction / PII review		

14. Final attestation controls

- ☐ Final package is complete, access-controlled, and discoverable.
- ☐ Current Microsoft documentation, licensing, cmdlet/API behavior, and portal behavior were revalidated before production use.
- ☐ The record distinguishes current-state entitlement evidence from historical grant/use chronology.

Auditor / reviewer

Completion date

15. Closure decision

- ☐ All required checklist items are complete or have documented exceptions.
- ☐ Open findings and exceptions have named owners and follow-up dates.
- ☐ Evidence retention and access controls are confirmed.

Final notes

Field reference

Compact operational reminders for a defensible Exchange permission audit

16. Core evidence principles

- ☐ Collect Full Access, Send As, and Send on Behalf separately; do not infer one from another.
- ☐ Expand groups for effective-access analysis while retaining the original group grant as the authoritative entitlement.
- ☐ Resolve trustees by immutable identifiers wherever available; names and SMTP addresses are display attributes.
- ☐ Treat application permissions and service principals as privileged non-user trustees, with explicit scope evidence.
- ☐ Preserve raw inherited / system entries even when operational views filter expected noise.
- ☐ Keep inventory evidence, change evidence, and usage evidence as separate evidence classes.
- ☐ Use complete snapshots at least quarterly and after major reorganizations; collect high-risk deltas more frequently.
- ☐ Require named ownership and time-bounded exceptions.

17. Implementation boundary

Current-state enumeration does not prove when a permission was granted or used. Retained snapshots and audit/change events are needed for chronology.

Group expansion can differ from token-time effective membership, especially for dynamic, nested, synchronized, or recently changed groups.

Deny and inheritance semantics are source-specific; test effective authorization rather than relying on a universal allow-minus-deny algorithm.

Application authorization can depend on consent, Exchange registration, scope configuration, protocol, token claims, and resource. Test the effective authorization path.

The framework supports control objectives such as least privilege, traceability, timely removal, and monitoring, but does not by itself establish legal or regulatory compliance.

18. Source note

Primary implementation authority should be current Microsoft Learn documentation for the relevant Exchange Online, Microsoft Graph / Entra, and Microsoft Purview capabilities. Revalidate syntax, supported versions, licensing, and retention behavior at execution time.

Canonical row

Target | TargetType | PermissionType | Trustee | TrusteeType | Inherited | Deny | Source | Scope | ReviewStatus | EvidenceDate